Application Security Requirements

Ref: 2.1
Product: iConnect Plus
Organisation: Cache Digitech
Classification: Internal — Confidential
Version: 2.0
Date: 2026-11-03
Deployment model: On-premises (Cache Digitech premises) · VPN for remote access
Audience: Developers, QA, security assessors, module leads

---

1. Purpose

Define **mandatory application security requirements** for iConnect Plus aligned with Architecture Lock v1.1 and on-premises deployment at Cache Digitech.

---

2. Authentication requirements

ID	Requirement	Implementation reference
AUTH-01	No cleartext password storage	bcrypt hashes in `sec_user`
AUTH-02	Session tokens not in `localStorage`	HttpOnly cookies
AUTH-03	MFA support for privileged users	TOTP (`mfa_enabled`)
AUTH-04	Account lockout after failed attempts	`ACCOUNT_LOCKOUT_THRESHOLD`
AUTH-05	Demo / default passwords disabled in prod	`ALLOW_DEMO_LOGIN=false`
AUTH-06	Refresh token reuse detection	`REFRESH_REUSE_DETECTION=true` (prod)
AUTH-07	Shorter access token for privileged admins	`JWT_PRIVILEGED_ACCESS_TOKEN_EXPIRE_MINUTES`

---

3. Authorization requirements

ID	Requirement	Implementation
AUTHZ-01	Deny-by-default on business routes	`require_permission`
AUTHZ-02	Permission catalog is SSOT	Module `permissions.py` + migrations
AUTHZ-03	UI routes ⊆ API permissions	CI sync gate
AUTHZ-04	Tenant isolation on all transactional queries	Repository filters
AUTHZ-05	System roles (`SUPER_ADMIN`, `TENANT_ADMIN`) tightly scoped	Seeded role packs

---

4. Input validation and API safety

ID	Requirement	Notes
IN-01	Pydantic v2 schemas for all request bodies	Routers thin
IN-02	Max string length on JSON fields	`API_MAX_ENTRY_STRING_LENGTH`
IN-03	Upload size limits	`API_MAX_UPLOAD_REQUEST_BYTES`
IN-04	Rate limits on login and writes	Env-configured

IN-05	OpenAPI UI disabled in production	`ENABLE_API_DOCS=false`

5. Data protection

ID	Requirement	Mechanism
DATA-01	UUID primary keys	DBS standard
DATA-02	Audit columns on transactional tables	`created_at`, `updated_by`, etc.
DATA-03	Soft delete only	No physical DELETE
DATA-04	Encrypt sensitive PII/finance fields	Fernet / `EncryptedText`
DATA-05	Secrets not in source control	`.env` on host, gitignore
DATA-06	Object storage on internal MinIO	`OBJECT_STORAGE_BACKEND=minio`

6. File upload and malware

ID	Requirement	Mechanism
FILE-01	Scan uploads when enabled	ClamAV `CLAMAV_ENABLED`
FILE-02	Fail closed when AV required	`CLAMAV_FAIL_OPEN=false`
FILE-03	Content-type / size validation	Upload safety module

7. Architecture and code structure

ID	Requirement	Reference
ARCH-01	Router → Service → Repository → DB	Architecture Lock
ARCH-02	No business logic in routers	DG-02
ARCH-03	No cross-module ORM imports	CI gate
ARCH-04	Workflow for business approvals	C-04
ARCH-05	Side effects via outbox / engines	Notification, Audit

8. Transport and deployment (on-premises)

ID	Requirement	Owner
NET-01	Application reachable only LAN/VPN	IT firewall
NET-02	TLS at nginx for user-facing HTTP	IT + Platform
NET-03	CORS limited to known internal origins	Platform env
NET-04	Production secrets rotated	**Template / Pending sign-off**

9. Logging and monitoring

ID	Requirement	Status
LOG-01	Request correlation ID	Implemented
LOG-02	Auth events auditable	Foundation audit

LOG-03	Central log retention policy	**Template / Pending sign-off**
LOG-04	No passwords/OTP in logs	Code review standard

10. Compliance mapping (summary)

Framework area	iConnect Plus control
Access control	RBAC + MFA + VPN (network)
Encryption	TLS + field encryption
Integrity	Optimistic locking, audit trail
Availability	On-prem HA — **Template / Pending sign-off**

11. Related documents

Ref	Document
2.2	Secure SDLC and Coding Standard
3.1	RBAC Matrix
3.2	Authentication and Session Design

Approval: Template / Pending sign-off